NoteMD — product and assurance status

15 October 2026 · prepared for Mohamed Mustafa

A summary of where the product stands, written to be presented. Section 1 is the headline; sections 2 and 3 are the detail behind it; section 4 is what is still open and who owns it.

---

1. The headline

No patient data leaves the EEA or the UK.

In August this was the single highest item on the risk register: transcripts, patient identifiers and dictation audio were sent to a processor in the United States. Transcription, letter generation, document reading and email delivery have each since been moved, and every location has been **verified from the provider's own response headers or by opening a real session** — not inferred from our configuration.

PROCESSING	PROVIDER	LOCATION
Live transcription (primary)	AssemblyAI Universal-3.5 Pro	EU data zone
Live transcription (fallback)	Deepgram Nova-3	Frankfurt
Enhanced dictation	Azure OpenAI	France Central
Letter generation	Azure OpenAI	France Central
Document reading (OCR)	Azure OpenAI	France Central
Email delivery	Azure Communication Services	United Kingdom
Database, storage, sign-in	Supabase	Ireland

Four processors — OpenAI, Resend, Google Cloud and Hugging Face — have been removed from the estate entirely.

Residency is enforced in the browser, not just promised. Audio streams directly from the clinician's device to the transcription provider, so the application's Content Security Policy names each vendor's EU endpoint and omits their global ones. If anything ever pointed the stream outside the EEA the browser would refuse the connection. This matters particularly for AssemblyAI, whose default endpoint routes to the nearest region *including the United States* — so the control guards against the vendor's own default, not merely against our mistake.

---

2. Clinical safety work

The product is a documentation tool whose output a clinician signs. The errors that matter are not crashes — they are text that reads correctly and is wrong.

Fabricated speech. Transcription models of this family do not return nothing when given nothing; trained on continuous speech, they produce fluent invented text from silence. Three controls now apply: the microphone level is measured and the clinician warned on screen while they can still fix it; audio containing no speech is not sent for transcription; and output bearing the marks of having been generated from nothing is rejected server-side rather than cleaned up, because a transcript a clinician can see is empty is safe and one quietly edited is not.

Fabrications at the end of recordings. Reported during testing and traced to a specific cause: dictation was cut into fixed ten-second segments, so a clinician who spoke for two seconds and then paused handed the model eight seconds of silence to account for. The tail was longest at the end of a recording. Segments now close at natural pauses.

Lost and reordered passages. Dictation segments were transcribed concurrently and appended as they returned, so a slow one could land out of order, and a failed one removed ten seconds of the consultation leaving no trace — the text simply ran on. Segments are now ordered, retried, and any that is lost triggers a re-transcription of the full recording. Where review is being skipped as a convenience, an unrecoverable gap diverts to review instead, because an incomplete transcript is exactly when review should not be skipped.

Patient name spelling. Names dictated aloud were transcribed phonetically and reached the letter misspelled, alongside a correctly spelled header. The correct spelling is now supplied to the model with an instruction to correct phonetic variants. The NHS number remains withheld.

Wrong-patient association. Every path by which transcribed text reaches a transcript re-checks the consultation it belongs to, so a slow request returning after the clinician has moved on cannot put one patient's words into another's record.

3. Consultation context

Clinicians can assemble background before a consultation: typed or dictated notes, and uploaded documents such as previous clinic letters, results and referrals. Scanned documents are read by optical character recognition.

Two design decisions are worth stating to a reviewer, because both were deliberate:

OCR introduced no new processor. Digital PDFs have their text extracted in the browser and never leave the device as an image. Only genuinely scanned pages are read, and by the model already used for letters — so no new vendor, no new data processing agreement, no new region to assess.

The summary informs the letter only if the clinician chooses. An error in a document summary entering a letter becomes established clinical history — "known hypertensive, on amlodipine 10mg" reads as fact, and nobody opens the source PDF to check a sentence that reads that way. The control is therefore off by default, the choice is recorded against each letter, and when it is on the model is told the background is unverified, may be misread from a scan, and must never introduce a diagnosis, medication or dose that appears only there.

Uploaded documents are the most directly identifying data in the system — a previous clinic letter typically carries name, NHS number, date of birth and address together. They follow the **audio** retention period rather than the ten-year transcript period, and the extracted text is deleted with the file.

---

4. What is still open

	OWNER
`gpt-transcribe` deployment on the Azure resource	**NoteMD**
Signed DPA with AssemblyAI, and written confirmation of their training-exclusion and retention position	**NoteMD**
DPO sign-off: lawful basis, Article 9 condition, and the France Central decision	**NoteMD / DPO**
Confirm Render's hosting region	**NoteMD**
Penetration test	Scheduled work

The one with a deadline. Enhanced dictation currently runs on `gpt-4o-transcribe`, which **Microsoft retires on 31 December 2026** — during the pilot. Its replacement, `gpt-transcribe`, is available in France Central but has not yet been deployed on the resource. It is a short task in the Azure portal; our side is then one configuration change. Changing transcription model re-opens clinical validation, so it is better done once, now, than twice.

France Central, not UK. UK South does not host the required models. France is in the EEA and the UK recognises the EEA as adequate, so the position is lawful — but it departs from the UK-only preference in the original specification and should be recorded in the DPIA as a decision rather than assumed. Worth asking the pilot Trust early whether they have a UK-only requirement; that is much cheaper to discover now than at DTAC review.

Supporting documents

DOCUMENT	CONTENTS
`TECHNICAL-ARCHITECTURE.md`	Full technical review, data flows, residency
`GDPR-PROCESSOR-PACK.md`	Sub-processor register, records of processing
`GDPR-STATUS.md`	Compliance position and remaining gaps
`evidence/assemblyai-residency.md`	Live transcription residency and controls
`evidence/azure-openai-cutover.md`	Azure migration and verification
`evidence/consultation-context.md`	New data category, retention, letter opt-in
`evidence/` (nine further documents)	IDOR testing, backups, recovery, log hygiene, security headers, data minimisation, production access, email delivery, wrong-patient and concurrency

Residency can be re-verified at any time from inside the product: **Settings → Data residency → Run check**. It opens a real session against each configured provider and reports the host, model and region. No audio is sent and no credential is returned.